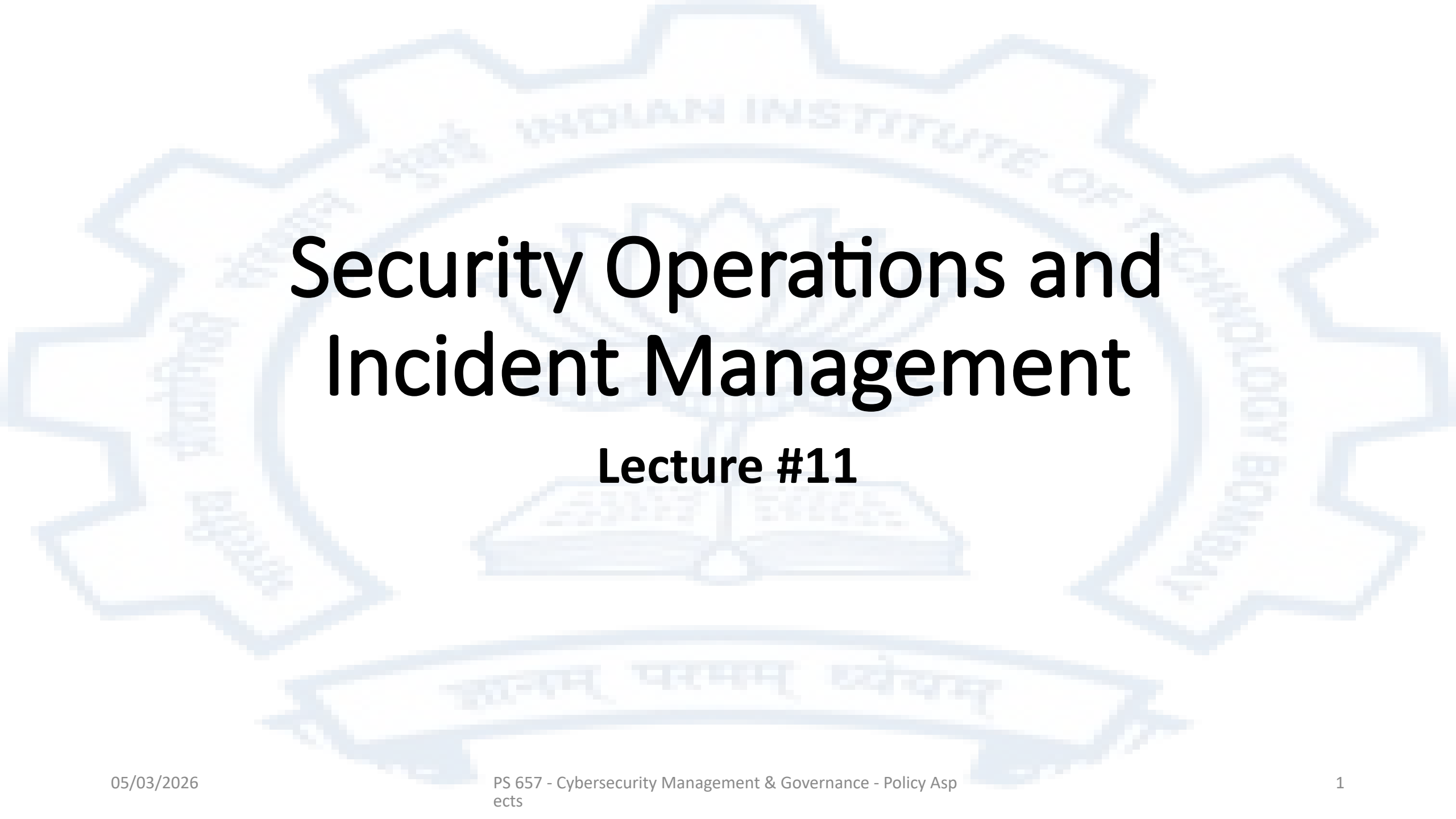




Security Operations and Incident Management

Lecture #11

Origins of the Concept

In 1981 James Anderson theorizes that the full protection of the information and communications infrastructure is impossible. Some key observations he makes are

- In order to achieve full protection full and ubiquitous control would be needed which would block or limit usefulness and usability
- From an economic standpoint the cost of protection vs the loss due to decreased or limited usage require a some sort of equilibrium between protection and openness, which generally tilts towards openness
- He promotes the use of detection techniques to complement protection

J. P. Anderson *et al.*, "Computer security threat monitoring and surveillance," Technical report, James P. Anderson Company, Fort Washington, Pennsylvania, Tech. Rep., 1980.

A Conceptual Model

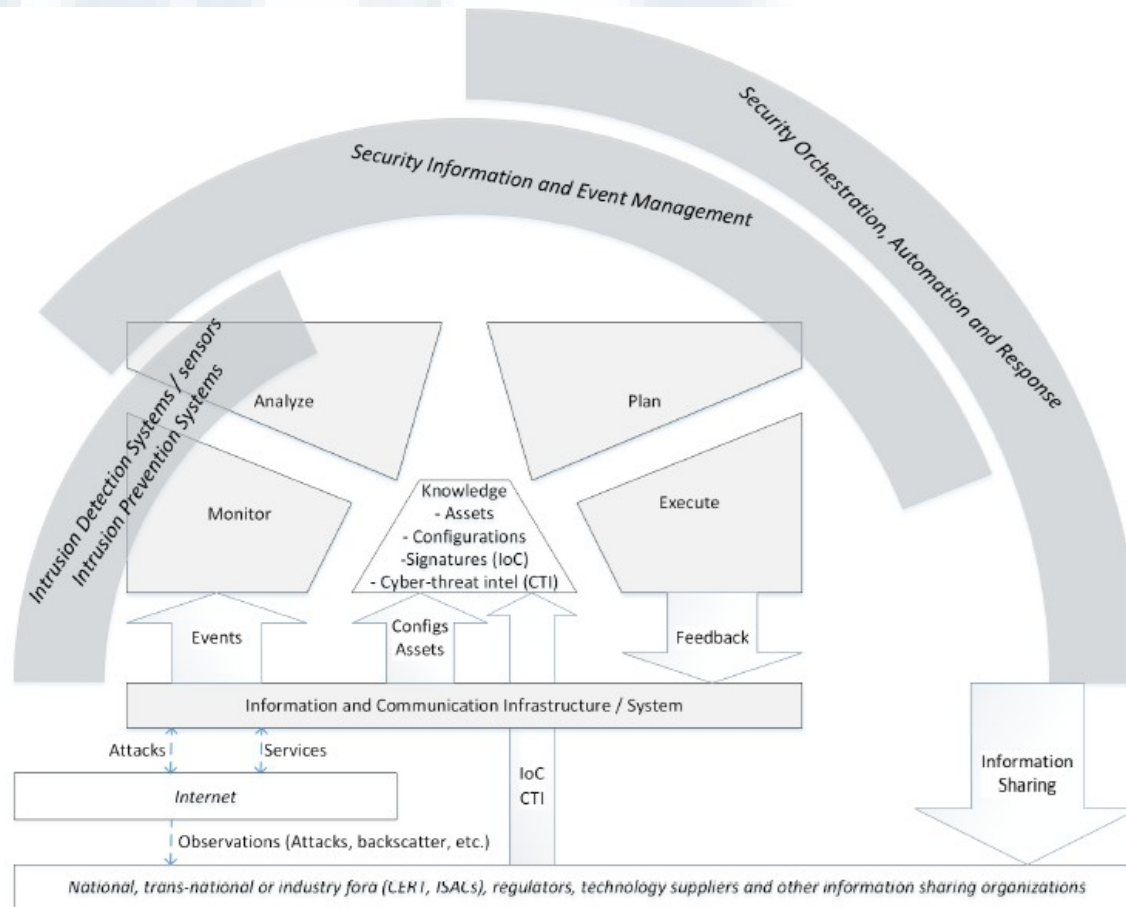


Figure 8.1: MAPE-K Autonomic computing loop instantiated to SOIM

- The **MAPE-K** model is
- Monitor
- Analyse
- Plan
- Act

In the context of certain Knowledge

Certain authors use the **OODA** Model which is

- Observe
- Orient
- Decide
- Act

CyBOK v1.1.0

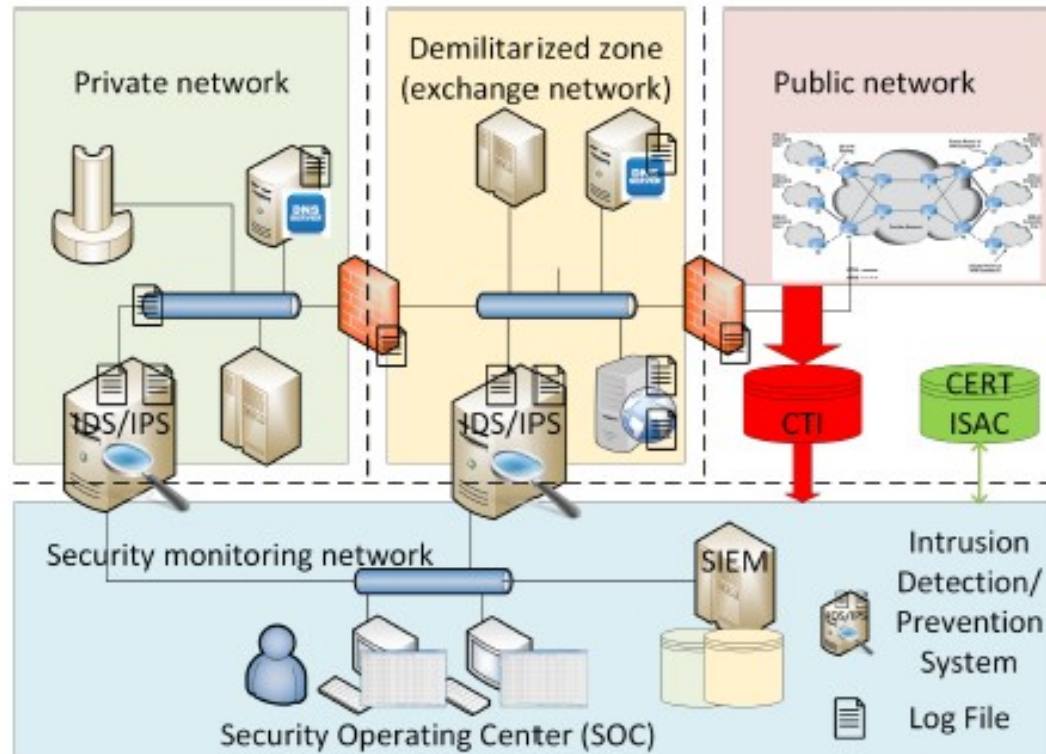
The placement of security systems in the model- 1

- Monitor – usually the monitor activity is done by some type of intrusion detection system. This should not be narrowly interpreted to mean just what we today call an IDS but any security system such as an antivirus or the authentication system which monitors login attempts etc
- Analyse – This activity, done by IDS systems, involves making decisions on whether the collected information constitutes evidence of an attack. This has matured to IPS where an additional capability to respond to suspected attacks has been added. However the need to pull in data from a wider range of systems and do more sophisticated multi-event processing led to the development of the SIEM arc

The placement of security systems in the model- 2

- Plan – This activity is in the realm of the SIEM (Security Incident and Event Management) Platform. This provides capabilities that help in collating information from many IDS systems and helping to carry out additional analysis and carry out initial planning
- Execute – This phase was mostly manual with some type of automation being implemented in SIEM platforms. The first three phases i.e. Monitor, Analyse and Plan are now completely automated in light of the tremendous volumes of data monitored. The newer trend is to implement Security Orchestration, Automation and Response (SOAR) to automate even the response to a large extent

A Typical SOC (Security Operations Centre) Deployment



Note that it is common industry practice to carry out other security activities like provisioning of identities, keys, penetration testing etc and call the entire operation as the SOC as opposed to just what is depicted in this diagram

Figure 8.2: Simplified deployment of SOIM technologies in an ICT infrastructure

CyBOK v1.1.0

Monitor

SOIM

Data Sources

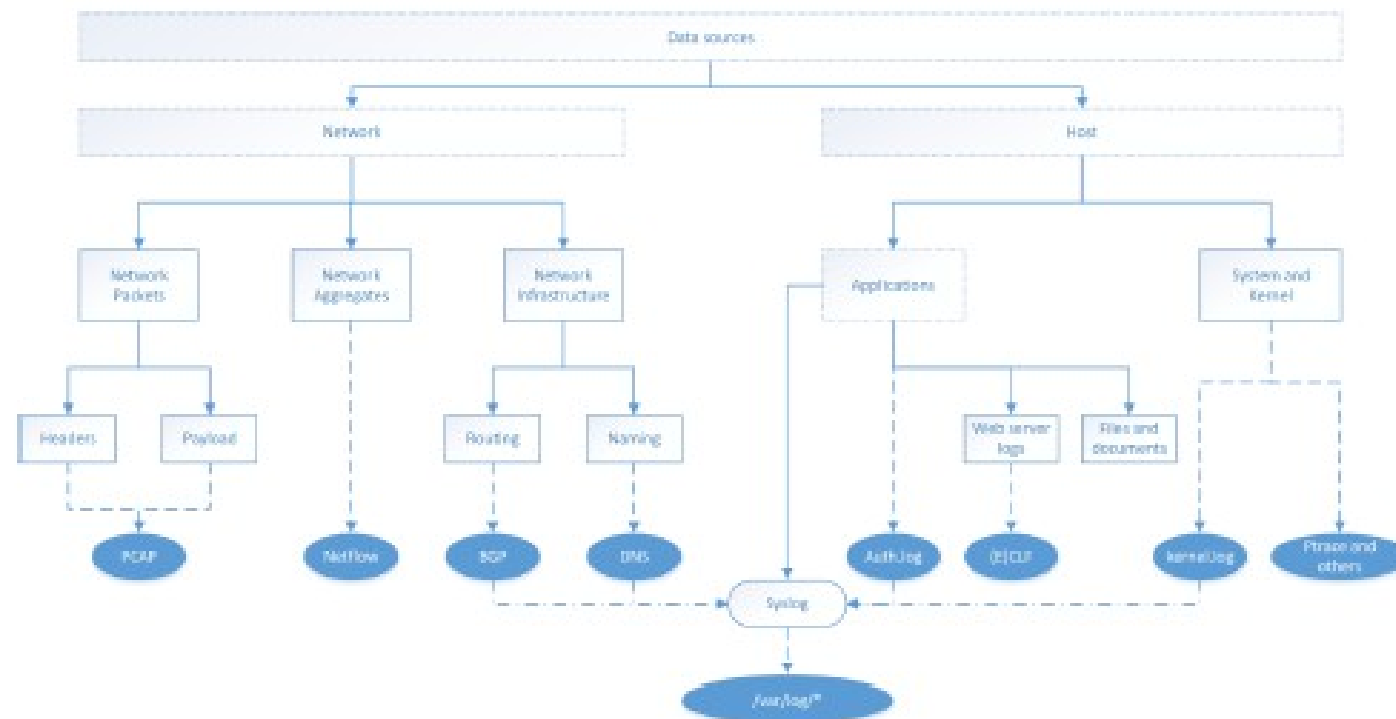


Figure 8.3: Data sources landscape

CyBOK v1.1.0

Network Data

There are several sources for network data. The most important of these are

- Network traffic
 - The pcap library and tcpdump and wireshark tools are easily available as open source
 - Requires an interface that can be placed in promiscuous mode
 - Analysis is done on the fly in full packet capture mode
 - pcap data is rarely stored due to sheer volume
 - Packet capture can be done silently and is almost undetectable
- Network Aggregates
 - Network aggregates count the numbers of packets sharing certain characteristics such as source, destination, protocol or interface
 - The most popular tool is Netflow
- Network infrastructure
 - Naming
 - Routing

Application Layer Data

- Web server logs
 - A frequent source of information is provided by web server and proxy logs, known as the Common Log Format (CLF) and Extended Common Log Format (ECLF). This format is a defacto standard provided by the Apache web server and others. While it is very similar to Syslog, there are no standards documents normalising the format.
- File and documents
 - Another source of application-level information that is particularly interesting and can be found both in transit (in networks) or at rest (in systems) comprises the documents produced by some of these applications. The introduction of rich document formats such as PDF, Flash or office suites, not to mention the rich HTML format used in mail exchanges today, has created a wealth of opportunity for attackers to include malware. Exchanged over the web or via email, they constitute another trace of exchange that can reveal malicious code embedded in these documents, such as macros or javascript.
- Other types of applications like databases, ERP systems etc also generate logs which may be useful in the understanding of and response to security incidents

Other sources

- OS logs
 - Early versions of most operating systems did not maintain extensive logs and also did not store entire paths
 - Modern versions of operating systems have many more logging capabilities however they may have to be explicitly turned on
- Syslog
 - Syslog provides a generic logging infrastructure
 - The current specification of Syslog is provided by RFC 5424. This new specification introduces several improvements over the original implementation.
 - Any device or application can log to syslog and this is a highly efficient way to aggregate logs

Syslog

- A Syslog entry is a timestamped text message coming from an identified source. It contains the following information in this order:
 - **Timestamp** The date and time of the event creation, usually in text format with a resolution up to the second. (The old spec for timestamps was lo-res i.e. MMM dd HH:mm:ss but now there is a provision for hi-res timestamps defined in ISO 8601 which allows for arbitrary precision in time.)
 - **Hostname** The name of the equipment generating the log. It might be a fully qualified name or an IP address, or the *localhost* for the local machine. Using IP addresses in private ranges or localhost may induce errors when consolidating logs.
 - **Process** The name of the process (program) generating the log.
 - **Priority** The priority (category and severity, computed according to a standard formula) of the log. In practice, it is often summed up according to severity on a scale of 0 (system panic and crash) to 7 (debugging information).
 - **PID** The process ID of the process generating the log.
 - **Message** An ASCII 7-bit message qualifying the information, provided by the developer of the application.
- Syslog is also a protocol running on UDP port 513
- Windows does not natively use syslog so either a SOIM system directly ingests windows logs or uses a tool to transfer windows logs to a syslog server

Analyse

SOIM

Event, Alert and Incident

- **event** : Any observable occurrence in a network or system. (Source = NIST IR 7298r2). Trace of activity provided by a computing environment. In the SOIM context, this is a piece of evidence logged that an activity was performed in the monitored system. Events are acquired sequentially by sensors to obtain a trace of the activity on a computer or network, to find indicators of compromise.
- **alert** : Notification that a specific attack has been directed at an organisation's information systems (Source = NIST IR 7298r2). In the SOIM context, an alert should refer to an event, or group of events, of interest from a security perspective, representing either an attack symptom or consequence. An alert is necessarily the outcome of an analysis process performed by an Intrusion Detection System sensor on event traces.
- **incident** : Actions taken through using computer networks that result in an actual or potentially adverse effect on an information system and/or the information residing therein. (Source = NIST IR 7298r2). In the SOIM context, an incident is described as a set of alerts that are considered evidence of a cybersecurity breach, generally a successful attack (although serious attempts, or attempts against critical systems, may also be considered incidents).

Analysis

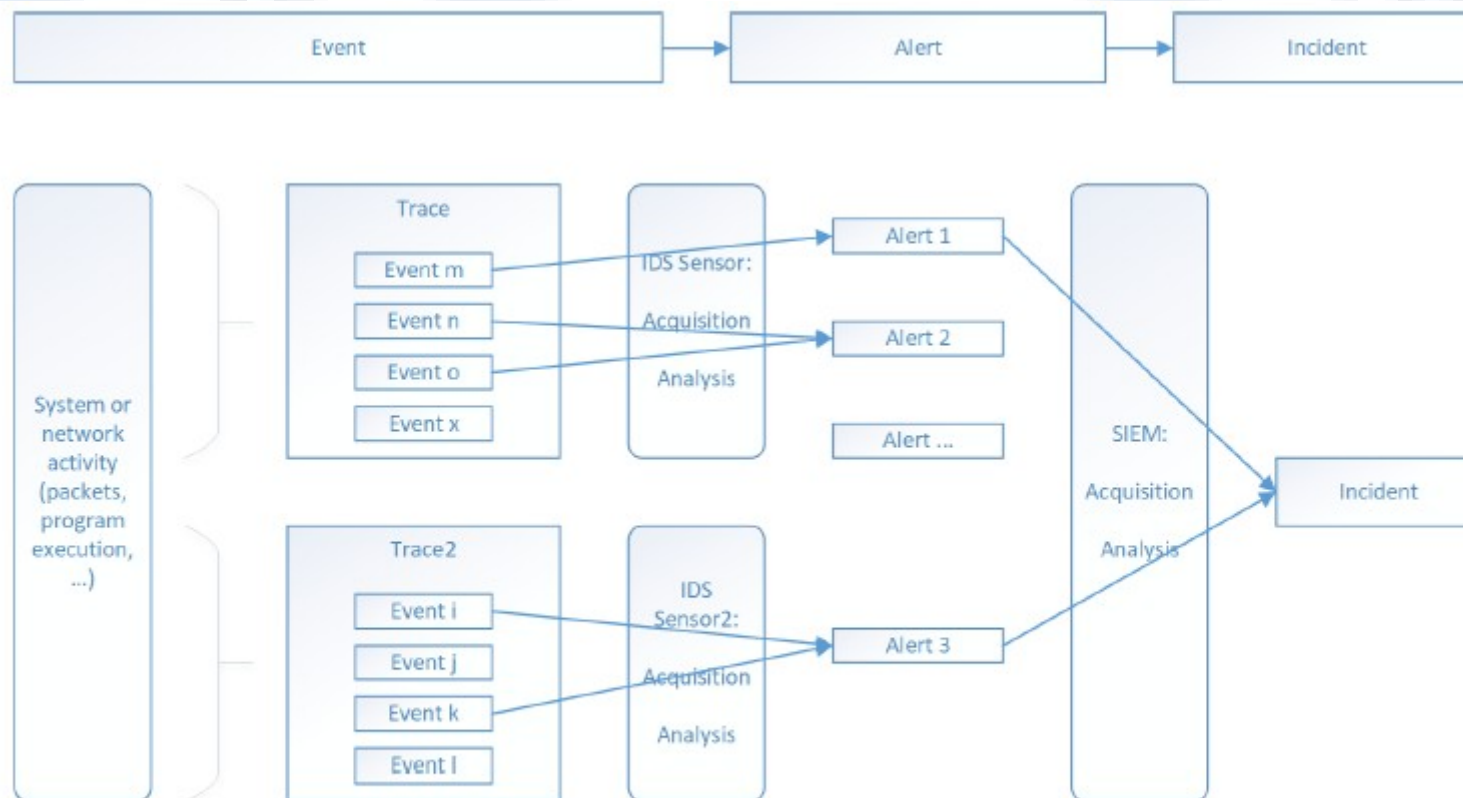


Figure 8.4: Analysis: from event to alert to incident

CyBOK v1.1.0

Analysis Methods

- Misuse detection
- Anomaly detection
- Blended misuse and anomaly detection
- Machine Learning

Misuse detection

- Misuse detection leverages the vast body of knowledge about software vulnerabilities and malicious code
- A misuse IDS seeks to discover evidence of known malicious events in the trace of events captured and when they are found informing the analyst about the vulnerability exploited and its impact
- The earliest Intrusion Prevention Systems in this area are antivirus engines, which capture execution traces such as system calls, library calls or assembly, identify known malicious patterns using so-called **signatures** that describe these malicious codes, and quarantine the associated container. The IDPS thus seeks exploits, very specific instances of malicious codes represented as bitstrings.

Misuse detection – advantages and disadvantages

- The main advantage of this technique is the ability to identify specifically the cause of an alert and therefore plan the mitigation and response more thoroughly.
- The main disadvantage of this technique is the need to have large databases of signatures which need to be constantly updated to deal with newer misuse cases, more indicators of compromise and the ability of malicious actors and modern malware to keep changing its form so as to render the older signatures less effective

Anomaly detection

- Anomaly detection refers to the characterization of what is normal in terms of several statistical parameters pertaining to the system of interest, and then determining if some event is an anomaly
- This requires choosing a model to represent the system which is a subject that may fall outside the cybersecurity domain and in the domain of statistics, networking, signal processing etc

Anomaly detection – advantages and disadvantages

- The main advantage of this technique is its independence from knowledge of specific vulnerabilities. Theoretically it is capable of detecting 0-day attacks provided attacks show up as deviations (anomalies) in the normal digital traces
- The disadvantages are
 - Pure statistical methods highlight anomalies that are hard to understand and qualify for analysts
 - The lack of precise diagnosis, and of a clear link to security (instead of an anomaly related to another cause) requires an in-depth understanding of both the monitored system and the detection process, which is hard to combine.

Use of machine learning

- Machine learning techniques are increasingly being leveraged to detect attacks
- There are several papers and products that use machine learning for network attack detection and network traffic classification
- At the system level there has been work on
 - Malware detection at the system call level
 - Malware detection at the file system level
 - For PDF files
 - Android malware detection

Plan

SOIM

SIEM- Centralizing data

The primary goal of a SIEM platform is to gather and centralize alert data from various sources so that an overall analysis can be made. This requires the following

- A communication channel from the IDS sensors that is secure and has sufficient capacity (bandwidth)
- Standardized formats for alerts
 - Since there are many types of sensors and alerts the typical approach is to define a large table with many possible attributes so a specific alert is usually “sparse” with respect to a row in the alert table
 - Newer methods for non-relational data and search are also becoming increasingly common

Communicating alerts

Communicating alerts requires the following

- **Schema** The schema defines the structure of messages and the type and semantic of the attributes. It also includes the definition or use of dictionaries. Many alert schemas, for example, rely on CVE to document attacks.
- **Encoding** The encoding defines how the messages and attributes are encoded to form a bitstring. Examples of textual format include Syslog, JSON XML or YAML. Examples of binary formats include BER, CER or BSON. Textual formats are usually easier to process because they can be read directly by humans. Binary formats are more compact, which eases storage and transport.
- **Transport protocol** The transport protocol describes how the alert bitstring is moved from one place to another. Examples of transport protocols include Syslog, IDXP, HTTP or AMQP. Transport protocols typically take care of the access control, confidentiality, compression and reliability of the communication.

Proliferation of formats

Syslog (RFC 5424) is the de-facto standard for SIEM platforms alert acquisition, as it is widely available, easy to understand and parse, and quite reliable. When using UDP, there is no transport-layer security. There is no guarantee of message integrity or delivery. Yet, in practice, it is very successful and scalable. Its drawback is the limitation of its schema (timestamp, origin and ASCII text string) and the size of the message (practically limited to 1000 bytes). This has led to a proliferation of formats

Format	Owner	Transport	Encoding	Structure	Number of attributes (keys)
CEF	HP/Arcsight	Syslog	Key/value	Flat	117
LEEF	IBM/QRadar	Syslog	Key/value	Flat	50
CIM	DMTF	Any	(XML)	UML	58
CADF	The Open Group, DMTF, (NetIQ)	Any	(JSON)	Classes with common attributes	48
CEE	MITRE	(Syslog)	JSON, XML	Structured: CEE event model, CEE profile	56
IDMEF	IETF	IDXP	XML	UML	166

Table 8.1: Formats characteristics summary

CyBOK v1.1.0

SIEM – The need for alert correlation

1. to reduce the number of alerts that the analyst has to process by grouping alerts together,
2. to add contextual elements to enable more accurate and faster analysis of the group of alerts,
3. to add alerts to ongoing higher-level planning and mitigation elements so that they are handled properly, and
4. to discard alerts that are considered false positives and do not require further processing.

Forms of alert correlation

- Correlation between alerts
- Correlation between alerts and the environment
- Correlation between alerts and external sources
- Incident and information exchange

Methods of alert correlation

- Rules based approach – First generation SIEMs
 - Explicit rules are required that correlate alerts
 - Use of relational databases to store alerts
 - The main drawbacks were
 - Difficulty in keeping the rule set current
 - Performance issues with relational databases in insert intensive applications
- Data intensive approach
 - Use of data processing techniques for correlation
 - Use of machine learning
 - Use of NoSQL databases

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and a banner at the bottom with the Sanskrit motto 'सत्यम् धर्मम् विद्यया' (Satyam Dharmam Vidhyaya). The text 'INDIAN INSTITUTE OF TECHNOLOGY BOMBAY' is written along the inner circle.

Execute

SOIM

Incident Management Lifecycle

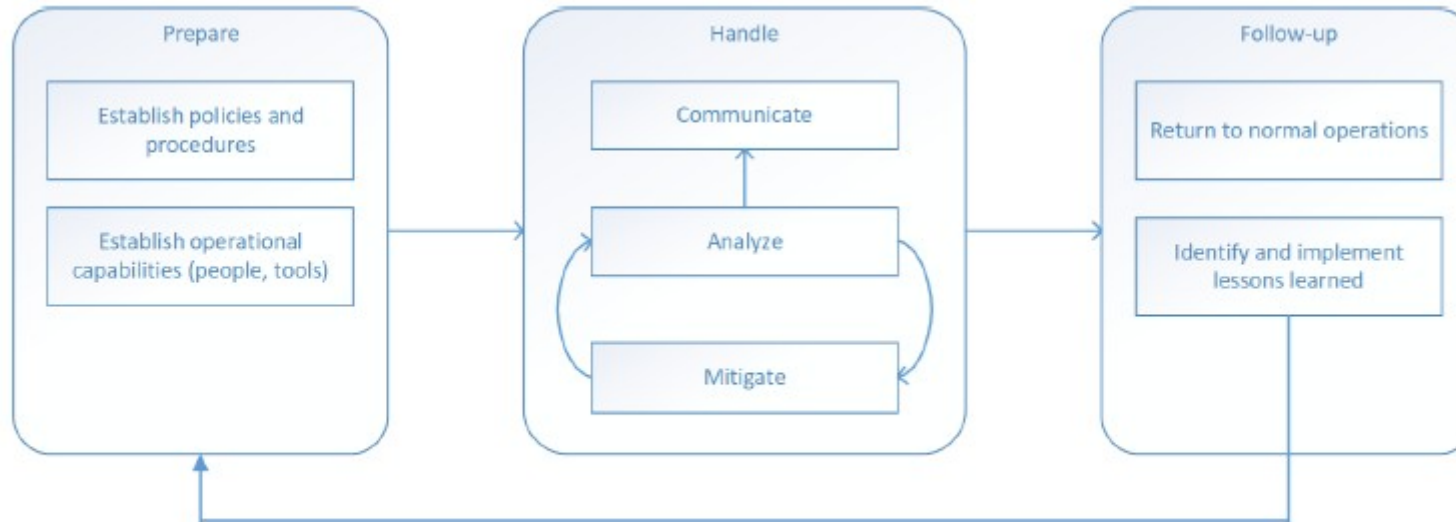


Figure 8.5: incident management lifecycle

- A significant part of the handle phase is manual
- The concept of SOAR (Security Orchestration and Response) aims to automate this phase as well

SOAR

In the context of Security

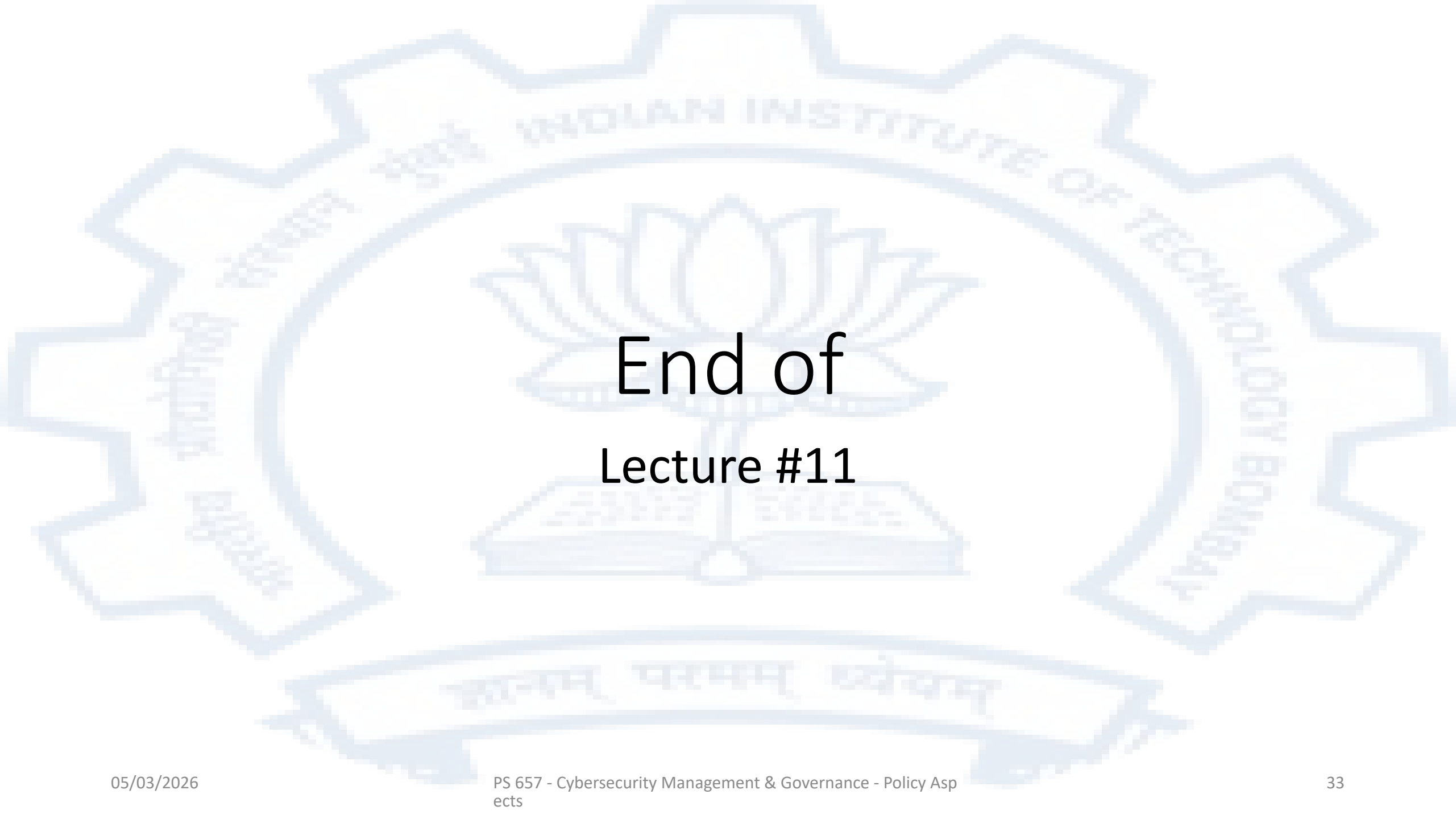
- Orchestration refers to the integration of various security tools
- Automation refers to the ability to carry out tasks without human intervention
- Response is the actions carried out when an incident takes place

SOAR is achieved by defining

- Playbooks which are human oriented documents describing what humans should do in the case of an incident
- A runbook is a playbook implemented in a security automation tool

To summarize

- It is not possible either technically or economically to prevent all attacks
- The discipline of SOIM deals with detecting attacks and responding to them
- The aspects of SOIM are
 - Monitor
 - Act
 - Plan
 - Execute
- The first three phases have been almost completely automated using various tools such as monitoring, intrusion detection and SIEM
- There is an increasing trend to automate the response as well and this is called SOAR

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and a banner at the bottom with the Sanskrit motto 'इत्यन्तं परमं ज्ञेयम्'. The text 'INDIAN INSTITUTE OF TECHNOLOGY BOMBAY' is written along the inner circle.

End of Lecture #11